

REPORT DI ANALISI MALWARE

Esercizio 5 – Analisi con ANY.RUN Sandbox

Analisi di due campioni malware identificati tramite sandbox dinamica

1. Introduzione

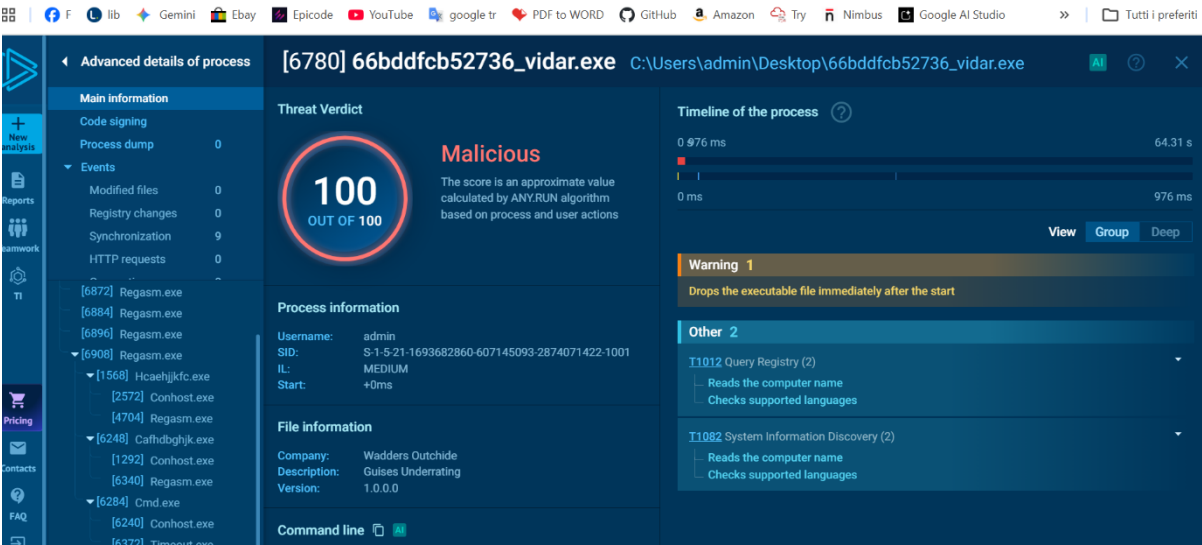
In questo esercizio ho analizzato due campioni di malware reali utilizzando la piattaforma di sandbox online ANY.RUN. L'obiettivo era studiare il comportamento dei file malevoli in un ambiente controllato, capire cosa fanno concretamente una volta eseguiti, e definire le azioni di remediation più appropriate.

ANY.RUN è uno strumento di analisi dinamica: esegue il file sospetto in una macchina virtuale e registra tutto ciò che accade – processi creati, connessioni di rete, modifiche al registro, file scritti su disco, e molto altro. Questo permette di analizzare la minaccia senza rischi per il sistema reale.

2. Campione 1 – Vidar Stealer (66bddfcb52736_vidar.exe)

2.1 Identificazione del file

Nome file	66bddfcb52736_vidar.exe
Percorso	C:\Users\admin\Desktop\66bddfcb52736_vidar.exe
PID principale	6780
Verdetto ANY.RUN	MALICIOUS – Score 100/100
Famiglia malware	Vidar Stealer
Tag	stealer, telegram, trojan
Sorgente analisi	ANY.RUN – Task 371957e1-d960-4b8a-8c68-241ff918517d



2.2 Cos'è Vidar Stealer

Vidar è uno degli stealer più diffusi e pericolosi in circolazione da diversi anni. Si tratta di un malware della categoria "information stealer", ovvero un programma progettato esclusivamente per rubare dati dalla macchina infetta e trasmetterli all'attaccante.

Il nome deriva dal dio norreno della vendetta. È attivo dal dicembre 2018 e viene venduto nel dark web secondo il modello MaaS (Malware-as-a-Service): chiunque può acquistarlo e configurarlo per colpire le vittime. Il prezzo varia dai 250 ai 700 dollari a seconda della versione.

Vidar è scritto in linguaggio C++ ed è tecnicamente un discendente (o una variante evoluta) di un altro stealer chiamato Arkei.

2.3 Cosa fa concretamente questo malware

Una volta eseguito sul sistema della vittima, Vidar agisce in modo silenzioso e rapido. Ecco cosa raccoglie e cosa fa:

- Ruba le credenziali salvate nei browser (Chrome, Firefox, Edge, ecc.)
- Esfiltra la cronologia di navigazione, inclusa quella del browser Tor
- Ruba i wallet di criptovalute presenti sulla macchina
- Cattura screenshot del desktop
- Raccoglie messaggi da applicazioni di messaggistica
- Legge informazioni di sistema: nome del computer, lingua, indirizzo IP
- Può scaricare e installare ulteriori malware sul sistema (funziona anche da loader)
- Comprime tutti i dati rubati in un archivio ZIP e li invia a un server C2 (Command & Control)

Dall'analisi ANY.RUN si osservano comportamenti tecnici specifici:

- Il processo principale spawna diversi processi figli di RegAsm.exe (strumento .NET legittimo usato per mascherare l'attività malevola)
- Viene rilevata la tecnica T1012 (Query Registry) – il malware legge il nome del computer e le lingue supportate dal sistema
- Viene rilevata la tecnica T1082 (System Information Discovery) – raccolta di informazioni sull'ambiente operativo
- Il warning "Drops the executable file immediately after the start" indica che il malware elimina se stesso subito dopo l'esecuzione per rendere più difficile l'analisi forense
- Vengono effettuate 9 operazioni di sincronizzazione, tipiche della comunicazione con server remoti

2.4 Perché è pericoloso

Il danno principale di Vidar non è la corruzione del sistema, ma il furto silenzioso di dati. La vittima non si accorge di niente mentre le sue credenziali, i suoi portafogli crypto e la sua cronologia vengono trasmessi all'attaccante. Le conseguenze possono includere furto di account, svuotamento di wallet, accesso non autorizzato a sistemi aziendali.

Vidar è configurato per non agire se rileva che il sistema è in Russia o in alcuni paesi dell'ex Unione Sovietica, il che suggerisce fortemente un'origine in quell'area geografica.

3. Campione 2 – Trojan.MSIL/Jalapeno (MSG.exe)

3.1 Identificazione del file

Nome file	MSG.exe
Hash SHA-256	325396d5ffca8546730b9a56c2d0ed99238d48b5e1c3c49e7d027505ea13b8d1
Dimensione	190.00 KB

Verdetto VirusTotal	56/72 vendor lo classificano come malevolo
Label minaccia principale	trojan.msil/jalapeno
Categorie	trojan, PUA (Potentially Unwanted Application)
Family labels	msil, jalapeno, stealer
Sorgente analisi	ANY.RUN – Task f1f20828-2222-46fb-a886-09f77581e67b

325396d5ffca8546730b9a56c2d0ed99238d48b5e1c3c49e7d027505ea13b8d1

56/72 security vendors flagged this file as malicious

Reanalyze Similar More

325396d5ffca8546730b9a56c2d0ed99238d48b5e1c3c49e7d027505ea13b8d1

MSG.exe

Size: 190.00 KB | Last Analysis Date: 2 months ago

peexe long-sleeps persistence spreader detect-debug-environment checks-user-input calls-wmi checks-cpu-name assembly

Community Score: 56 / 72 (-10)

DETECTION DETAILS RELATIONS BEHAVIOR COMMUNITY 7

Join our Community and enjoy additional community insights and crowdsourced detections, plus an API key to automate checks.

Popular threat label: trojan.msil/jalapeno

Threat categories: trojan pua

Family labels: msil jalapeno stealer

Security vendors' analysis

AhnLab-V3 Trojan.Win.MalwareX-gen.C5659371 Alibaba TrojanPSW:MSIL/LummaC.9bb96b68

3.2 Cos'è Trojan.MSIL/Jalapeno

Jalapeno è una famiglia di trojan sviluppata in ambiente .NET/MSIL (Microsoft Intermediate Language), ovvero il codice compilato per la piattaforma .NET di Windows. La sigla MSIL nell'etichetta indica proprio questo: è un eseguibile .NET, il che lo rende relativamente facile da decompilare, ma al tempo stesso molto flessibile e adattabile.

Il label aggiuntivo "stealer" (stealer + componente di controllo remoto) indica che questo campione combina funzionalità di furto dati con capacità di controllo remoto sulla macchina infetta.

3.3 Cosa fa concretamente questo malware

Dalle analisi comportamentali emergono le seguenti caratteristiche:

- Persistence – il malware si garantisce la sopravvivenza al riavvio del sistema, probabilmente tramite chiavi di registro o task pianificate
- Spreader – ha capacità di propagarsi ad altri sistemi, ad esempio tramite supporti rimovibili (USB) o condivisioni di rete
- Detect-debug-environment – prima di agire verifica se è in esecuzione all'interno di una sandbox o sotto debugger, cercando di eludere l'analisi
- Checks-user-input – monitora l'attività dell'utente, potenzialmente per keylogging o per capire quando il sistema è attivo
- Calls-WMI – utilizza Windows Management Instrumentation per raccogliere informazioni di sistema
- Checks-cpu-name – rileva il processore installato, tecnica usata per evitare ambienti virtuali
- Long-sleeps – rimane in attesa per lunghi periodi prima di agire, tecnica anti-sandbox (le sandbox analizzano per un tempo limitato)

Il Community Score negativo (-10) su VirusTotal e i 7 commenti della community confermano che il file è stato analizzato e segnalato da più ricercatori come minaccia reale e attiva.

3.4 Perché è pericoloso

Questo campione è particolarmente insidioso per tre motivi: si nasconde rilevando ambienti virtuali (evasione), persiste sul sistema anche dopo il riavvio, e può diffondersi autonomamente ad altri dispositivi della rete. La combinazione di queste capacità lo rende una minaccia persistente e potenzialmente laterale, capace di spostarsi all'interno di una rete aziendale.

4. Confronto tra i due campioni

Caratteristica	Campione 1 – Vidar	Campione 2 – Jalapeno
Tipo	Information Stealer	Trojan / Stealer-C
Verdetto	100/100 – Malevolo	56/72 vendor – Malevolo
Furto credenziali	Sì	Sì (stealerc)
Persistenza	Non rilevata esplicitamente	Sì (persistence tag)
Anti-sandbox	Sì (si autoelimina)	Sì (long-sleep, debug check)
Diffusione laterale	No	Sì (spreader)
Linguaggio	C++	.NET/MSIL
Comunicazione C2	Sì (sincronia con server remoti)	Probabile

5. Scelte di Remediation

5.1 Campione 1 – Vidar Stealer

Classificazione: VERO POSITIVO

Il verdetto è inequivocabile: score 100/100 su ANY.RUN, comportamento coerente con la famiglia Vidar documentata, tecniche MITRE ATT&CK rilevate. Non ci sono dubbi sulla natura malevola del file.

Azioni raccomandate:

- QUARANTENA IMMEDIATA del file e di tutti i processi correlati (RegAsm.exe figli)
- ELIMINAZIONE definitiva del file dopo la quarantena e analisi forense
- BLACKLIST dell'hash del file (SHA-256) su tutti gli endpoint della rete tramite EDR/antivirus
- Verifica immediata se il malware ha già comunicato con server C2: analisi dei log di rete per connessioni sospette outbound
- RESET OBBLIGATORIO di tutte le password dell'utente coinvolto (browser, email, VPN, accessi aziendali)
- Verifica dei wallet di criptovaluta per eventuali transazioni non autorizzate
- NON classificare come falso positivo: il comportamento è troppo specifico e documentato